

Individuell inlämningsuppgift

Workshop 2 - MITRE ATT&CK och hotanalys

Syfte

Denna individuella inlämningsuppgift följer upp Workshop 2 och tränar förmågan att använda MITRE ATT&CK, TTP, defensiv hotanalys, attackkedjor, försvarsfrågor, källor, spårbarhet och koppling till projektarbete.

Viktig avgränsning

Uppgifterna ska användas för analys, dokumentation och försvar. Beskriv inte tekniska genomförandesteg för angrepp. Fokusera på vad ett säkerhetsteam behöver förstå, upptäcka, förhindra och följa upp.

Instruktion till studenten

- Uppgiften genomförs individuellt och lämnas in enligt lärarens instruktion i Canvas.
- Uppgiften täcker kursmål 1, 2, 6 och 11.
- Du får använda materialet från Workshop 2, MITRE ATT&CK, kursmaterial och egna anteckningar.
- Du får använda generativa AI-assistenter och AI-assisterade säkerhetsverktyg, dock ska du beskriva eventuell AI-användning och vad som kontrollerats manuellt.
- Fokusera på tydliga resonemang, spårbarhet och defensiv analys.
- Dina svar ska visa att du kan använda begreppen, inte bara återge definitioner.
- Om du är osäker: skriv vad du är osäker på och hur du skulle följa upp det.

Översikt

Del	Fokus	Uppgifter
Del 1	Förstå MITRE ATT&CK som analysramverk	1-4
Del 2	TTP: Tactic, Technique och Procedure	5-8
Del 3	Bygg en defensiv attackkedja	9-12
Del 4	Försvarsfrågor och Blue/Purple-perspektiv	13-16
Del 5	Källor, spårbarhet och kvalitet	17-20
Del 6	Koppling till backlog, sprint och Workshop 3	21-24

Del 1 - Förstå MITRE ATT&CK som analysramverk

Uppgift 1

Beskriv med egna ord vad MITRE ATT&CK används till i ett säkerhetsteam.

Svarsinstruktion: Skriv 150-250 ord. Fokusera på analys, språk, struktur och försvarsperspektiv.

MITRE ATT&CK används i ett säkerhetsteam som ett gemensamt ramverk för att beskriva och analysera kända angriparbeteenden. Jag ser det främst som ett sätt att skapa struktur i hotanalysen. Istället för att bara säga att något verkar misstänkt kan teamet koppla observationer till tactics och techniques och diskutera vad angriparen försöker uppnå och vilket beteende som har observerats.

Ramverket kan användas av exempelvis SOC-analytiker, threat intelligence och incident response. Det hjälper teamet att jämföra händelser, identifiera möjliga luckor i övervakningen och prioritera vilka risker som bör hanteras först. Om en teknik är relevant för organisationens miljö men saknar bra loggning eller detektion blir det tydligt att detta kan vara ett förbättringsområde.

ATT&CK ersätter inte den egna analysen. Kontexten är fortfarande viktig eftersom samma observation kan ha en legitim förklaring. Därför tycker jag att den största nyttan är att ramverket ger ett gemensamt språk och en struktur för att gå från observation till analys och vidare till försvar, uppföljning och förbättring.

Uppgift 2

Förklara varför ATT&CK inte ska användas som en checklista för att "göra attacker".

Svarsinstruktion: Skriv 150-250 ord. Beskriv skillnaden mellan analysramverk och angreppsinstruktion.

ATT&CK ska inte användas som en checklista för att "göra attacker" eftersom syftet med ramverket är att beskriva och analysera observerade eller kända beteenden, inte att ge steg-för-steg-instruktioner. En technique visar på en typ av beteende och hur den kan förstås i en större attackkedja. Det betyder inte att ramverket ska tolkas som en manual som man ska följa från början till slut.

I ett defensivt säkerhetsarbete använder man istället ATT&CK för att ställa frågor. Exempelvis: Har vi tillräcklig loggning för att kunna upptäcka detta beteende? Finns det en kontroll som minskar risken? Vilken information saknas innan vi kan dra en slutsats? På så sätt blir fokus förståelse och försvar.

En checklista kan också skapa en falsk bild av att alla tactics och techniques alltid måste förekomma. Verkliga incidenter varierar mycket. Därför behöver man använda kontext, källor och professionell bedömning. Jag skulle beskriva ATT&CK som en karta över beteenden och samband, medan en angreppsinstruktion skulle beskriva exakt hur något genomförs. Det är två helt olika saker.

Uppgift 3

Välj fem tactics från Enterprise Matrix och beskriv vad varje tactic betyder på en övergripande nivå.

Svarsinstruktion: Använd egna ord. Undvik tekniska genomförandedetaljer.

1. Initial Access - handlar övergripande om hur en angripare får en första möjlighet att nå en miljö.
2. Execution - handlar om att ett beteende eller en process körs i miljön och att angriparen försöker få sin aktivitet genomförd.
3. Persistence - handlar om att försöka behålla åtkomst eller kunna fortsätta vara närvarande över tid.
4. Discovery - handlar om att samla information och förstå den aktuella miljön, till exempel vilka system och resurser som finns.
5. Impact - handlar om den effekt som en angripares aktivitet kan få för verksamheten, exempelvis störningar eller förlorad tillgänglighet.

Uppgift 4

Beskriv hur ATT&CK kan stödja kommunikationen mellan red team, blue team och ledning.

Svarsinstruktion: Skriv 200-300 ord. Ta upp gemensamt språk, spårbarhet och prioritering.

ATT&CK kan stödja kommunikationen mellan red team, blue team och ledning eftersom ramverket ger ett gemensamt språk. Red team kan beskriva vilka typer av angriparbeteenden som har simulerats eller analyserats, medan blue team kan koppla samma beteenden till loggning, detektion och skydd. Ledningen behöver inte alltid förstå alla tekniska detaljer, men kan få en tydligare bild av vilka risker och förbättringsområden som finns.

Spårbarheten blir också bättre när observationer kopplas till en tactic eller technique och till den källa som används. Då går det att följa varför en bedömning har gjorts. Om en annan person senare granskar analysen kan personen förstå både slutsatsen och underlaget bakom den.

Jag tycker också att ATT&CK hjälper vid prioritering. Alla möjliga risker kan inte hanteras samtidigt. Teamet kan därför bedöma vilka beteenden som är mest relevanta för den egna miljön och vilka delar som har svagast detektionsförmåga. I ett purple team-perspektiv blir detta särskilt användbart eftersom red och blue team kan jämföra angriparbeteende och försvar i samma struktur. Det gör att resultatet lättare kan omvandlas till konkreta förbättringar och följas upp.

Del 2 - TTP: Tactic, Technique och Procedure

Uppgift 5

Förklara skillnaden mellan tactic, technique och procedure.

Svarsinstruktion: Använd ett eget defensivt exempel. Håll dig på konceptuell nivå.

En tactic beskriver varför ett angriparbeteende sker, alltså vilket övergripande mål angriparen försöker uppnå. En technique beskriver vilken typ av beteende som används för att uppnå målet. En procedure beskriver hur ett visst beteende har observerats eller beskrivits i ett specifikt sammanhang.

Ett defensivt exempel kan vara att ett säkerhetsteam undersöker misstänkt aktivitet som verkar handla om att samla

information om en miljö. Tacticen kan då vara Discovery. En relevant technique beskriver vilken typ av informationsinsamling som analyseras. Proceduren blir sedan den konkreta observationen i just incidenten, exempelvis vilka typer av loggar eller aktiviteter som teamet har sett. Försvaret fokuserar då på att bedöma om observationen är rimligt mappad och vilka signaler som kan användas för upptäckt.

Uppgift 6

Skapa en TTP-förklaring för tre valfria ATT&CK-tekniker.

Svarsinstruktion: För varje teknik: skriv tactic, technique och en kort procedure-beskrivning utan operativa instruktioner.

Teknik 1: Tactic: Discovery. Technique: System Information Discovery. Procedure: Analysen beskriver en situation där en aktör samlar övergripande information om en miljö. Teamet skulle bedöma observationen utifrån tillgängliga loggar och kontext.

Teknik 2: Tactic: Credential Access. Technique: OS Credential Dumping. Procedure: I en incident kan säkerhetsteamet se indikationer på aktivitet som rör åtkomst till autentiseringsuppgifter. Det ska analyseras defensivt utan att beskriva hur aktiviteten utförs.

Teknik 3: Tactic: Impact. Technique: Data Encrypted for Impact. Procedure: Teamet kan analysera tecken på att data påverkas på ett sätt som kan störa verksamheten och koppla detta till incidentens möjliga konsekvenser.

Uppgift 7

Välj en tactic och identifiera tre tekniker som kan höra hemma inom den.

Svarsinstruktion: Motivera varför teknikerna passar in i tacticen.

Jag väljer tacticen Discovery. Tre tekniker som kan höra hemma inom denna tactic är System Information Discovery, File and Directory Discovery och Account Discovery.

De passar inom Discovery eftersom det övergripande syftet är att skapa en bättre förståelse för den miljö som analyseras eller där en angripare befinner sig. System Information Discovery kan handla om att få en översikt över systemet. File and Directory Discovery handlar om att identifiera relevant information i form av filer och kataloger. Account Discovery handlar om att förstå vilka konton och identiteter som finns.

Jag tycker att de hör ihop på tactic-nivå eftersom målet är informationsinsamling, men de skiljer sig på technique-nivå genom vilken typ av information som är relevant. I en riktig analys måste man ändå kontrollera kontexten eftersom legitim administration kan ge liknande observationer.

Uppgift 8

Beskriv varför det kan vara svårt att mappa en observation till rätt teknik.

Svarsinstruktion: Ta upp osäkerhet, kontext, datakvalitet och behov av källor.

Det kan vara svårt att mappa en observation till rätt teknik eftersom samma typ av signal kan ha flera möjliga förklaringar. En loggrad visar inte alltid varför en aktivitet utfördes. Det betyder att en första mappning kan vara en hypotes snarare än ett säkert svar.

Kontexten är därför viktig. Man behöver exempelvis förstå vilken typ av system det gäller, vilken användare som var involverad och om aktiviteten är normal i organisationen. Datakvalitet påverkar också analysen. Om loggar saknas, är ofullständiga eller har fel tidsstämplar kan viktiga delar av händelseförloppet saknas.

Jag skulle därför använda ATT&CK tillsammans med tydliga källor och dokumentera min motivering. Om flera tekniker verkar möjliga bör osäkerheten skrivas ner i stället för att låtsas att mappningen är säker. En granskning av någon annan i gruppen kan också hjälpa till att upptäcka alternativa tolkningar.

Del 3 - Bygg en defensiv attackkedja

Uppgift 9

Bygg en enkel attackkedja med 3-5 steg.

Svarsinstruktion: Använd tactics som etiketter. Syftet är analys och försvar, inte teknisk genomförandeinstruktion.

1. Initial Access - första misstänkta kontakten eller åtkomsten identifieras.
2. Discovery - aktivitet observeras som tyder på att miljön kartläggs.
3. Credential Access - indikationer på aktivitet kopplad till autentiseringsuppgifter analyseras.
4. Persistence - teamet undersöker om det finns tecken på att åtkomst försöker behållas.
5. Impact - eventuell påverkan på verksamhet, data eller tillgänglighet bedöms.

Uppgift 10

Beskriv varje steg i er kedja med "varför", "hur" och "vad såg vi?".

Svarsinstruktion: Koppla till TTP-modellen: tactic, technique och procedure.

Initial Access: Varför? För att skapa en första möjlighet att nå miljön. Hur? Vi beskriver det på tactic-nivå och analyserar tillgängliga observationer. Vad såg vi? En första misstänkt händelse eller åtkomstindikator.

Discovery: Varför? För att förstå miljön. Hur? Genom beteenden som kan kopplas till informationsinsamling. Vad såg vi? Observationer som behöver jämföras med normal aktivitet.

Credential Access: Varför? För att få tillgång till identitetsrelaterad information. Hur? En relevant technique används som analyskategori. Vad såg vi? Indikationer som kräver vidare kontroll.

Persistence och Impact följs sedan upp genom att analysera om åtkomst försöker behållas och vilken faktisk eller

möjlig påverkan som kan ha uppstått. I varje steg skiljer jag mellan tactic (varför), technique (vilken typ av beteende) och procedure (vad som observerades i just fallet).

Uppgift 11

Identifiera vilka steg i attackkedjan som är mest osäkra.

Svarsinstruktion: Beskriv vad ni behöver veta mer om för att göra analysen bättre.

De mest osäkra stegen är Initial Access och Credential Access eftersom vårt underlag kan vara begränsat. En första misstänkt observation visar inte automatiskt hur åtkomst uppstod, och en signal kopplad till autentiseringsuppgifter betyder inte säkert att en specifik technique har använts.

För att förbättra analysen behöver vi mer kontext, till exempel tidslinje, relevanta loggar och information om vad som är normal aktivitet i miljön. Vi behöver också kontrollera källor och jämföra alternativa ATT&CK-mappningar. Det är viktigt att dokumentera vad som är bekräftat, vad som är sannolikt och vad som fortfarande är osäkert.

Uppgift 12

Rita eller beskriv attackkedjan som en enkel kedja från första kontakt till påverkan.

Svarsinstruktion: Använd pilar och korta rubriker. Om ni skriver digitalt kan ni använda tabell eller punktlista.

Initial Access → första misstänkta kontakt/åtkomst → Discovery → kartläggning av miljön → Credential Access → indikationer kopplade till autentiseringsuppgifter → Persistence → möjlig fortsatt närvaro → Impact → bedömning av verksamhetspåverkan.

Del 4 - Försvarsfrågor och Blue/Purple-perspektiv

Uppgift 13

Formulera minst en försvarsfråga per steg i attackkedjan.

Svarsinstruktion: Exempel: Hur skulle detta kunna upptäckas? Vilken signal, rutin eller kontroll kan vara relevant?

Initial Access: Hur kan vi upptäcka ovanliga eller oväntade åtkomstförsök?

Discovery: Vilka signaler kan skilja normal administration från ovanlig kartläggning av miljön?

Credential Access: Har vi relevant loggning och rutin för att följa upp misstänkt aktivitet kopplad till autentiseringsuppgifter?

Persistence: Vilka kontroller kan visa om en obehörig förändring försöker skapa långvarig åtkomst?

Impact: Hur upptäcker vi tidigt förändringar som kan påverka tillgänglighet eller verksamhetskritiska data?

Uppgift 14

Välj två tekniker och resonera kring möjliga detektionssignaler.

Svarsinstruktion: Håll svaret på konceptuell nivå. Beskriv typer av signaler, inte tekniska exploit-steg.

Jag väljer System Information Discovery och Data Encrypted for Impact. För den första tekniken kan relevanta signaler vara ovanliga mönster av informationsinsamling, avvikande processbeteenden eller aktiviteter som sker från ett konto som normalt inte utför sådana uppgifter. En enskild signal räcker dock inte alltid, så kontext och normalbild behövs.

För Data Encrypted for Impact kan säkerhetsteamet titta efter breda och ovanliga förändringar i data, störningar i tillgänglighet eller ett stort antal relaterade larm under kort tid. Detektionssignaler bör kopplas till en tydlig baslinje och följas upp med andra datakällor för att minska risken för falska positiva resultat.

Uppgift 15

Välj två tekniker och resonera kring möjliga riskreducerande åtgärder.

Svarsinstruktion: Beskriv organisatoriska, tekniska eller processmässiga åtgärder.

För System Information Discovery kan riskreducerande åtgärder vara principen om minsta privilegium, tydliga behörighetsnivåer och tillräcklig loggning för att kunna följa upp avvikande beteenden. Regelbundna granskningar av administrativa konton kan också minska risken.

För Data Encrypted for Impact är fungerande säkerhetskopior, återställningstester och segmentering viktiga åtgärder. Även incidentrutiner och tydligt ansvar kan minska konsekvenserna. Jag tycker att kombinationen av teknik och process är viktig, eftersom ett skydd inte bara handlar om att stoppa en händelse utan också om hur snabbt organisationen kan upptäcka, begränsa och återhämta sig.

Uppgift 16

Beskriv hur ett säkerhetsteam kan använda en attackkedja för att förbättra sitt försvar.

Svarsinstruktion: Skriv 200-300 ord. Ta upp lärande, prioritering och uppföljning.

Ett säkerhetsteam kan använda en attackkedja som ett verktyg för att förstå ett händelseförlopp och hitta var försvaret kan förbättras. Genom att dela upp analysen i tydliga steg blir det lättare att se vilka observationer som finns, vilka antaganden som har gjorts och var information saknas. Teamet kan sedan koppla varje steg till relevanta försvarsfrågor.

Attackkedjan stödjer också lärande. Efter en övning eller incident kan teamet gå tillbaka till kedjan och fråga vad som fungerade bra och vad som upptäcktes för sent. Om ett steg saknade relevant loggning kan det bli ett förbättringsarbete. Om en kontroll fanns men inte användes på rätt sätt kan processen behöva ses över.

Prioritering blir enklare eftersom alla förbättringar inte har samma värde. Teamet kan fokusera på de steg som är

mest relevanta för organisationen och där konsekvensen eller osäkerheten är störst. För mig är det viktigt att attackkedjan inte ses som en exakt mall för alla incidenter. Den är ett analysverktyg som behöver uppdateras när ny information kommer. Uppföljning kan sedan ske genom backlog, nya kontroller och regelbundna reviews.

Del 5 - Källor, spårbarhet och kvalitet

Uppgift 17

Dokumentera vilka källor ni använder i er ATT&CK-analys.

Svarsinstruktion: Skriv minst tre källor eller länkar. Beskriv kort vad varje källa bidrar med.

1. MITRE ATT&CK – <https://attack.mitre.org/> Bidrar med själva ramverket och beskrivningar av tactics och techniques.
2. MITRE ATT&CK Enterprise Matrix – <https://attack.mitre.org/matrices/enterprise/> Hjälper till att placera techniques i ett större sammanhang och förstå tactics.
3. CISA – Best Practices for MITRE ATT&CK Mapping – <https://www.cisa.gov/news-events/news/best-practices-mitre-attckr-mapping> Bidrar med stöd för hur mappning bör motiveras och kvalitetssäkras.

Jag använder källorna för att kontrollera begrepp och motivera min analys, inte som en ersättning för egen bedömning.

Uppgift 18

Beskriv hur ni säkerställer att er TTP-mappning är rimlig.

Svarsinstruktion: Ta upp källa, motivering, osäkerhet och gruppgranskning.

Jag säkerställer att TTP-mappningen är rimlig genom att börja med det som faktiskt har observerats och sedan jämföra det med beskrivningar i relevanta källor. Varje mappning ska ha en kort motivering: vilken observation ligger bakom och varför passar den bättre än andra möjliga tolkningar?

Jag ska också dokumentera osäkerheten. Om underlaget inte räcker för att avgöra exakt teknik bör det framgå. Därefter kan en annan person i gruppen granska mappningen och försöka hitta alternativa förklaringar. Gruppgranskning minskar risken för att vi fastnar i vår första tolkning. Slutligen bör källor och beslut vara spårbara så att analysen kan följas upp och ändras när ny information tillkommer.

Uppgift 19

Skapa en mini-Definition of Done för en färdig hotanalys.

Svarsinstruktion: Lista minst fem kriterier. Kriterierna ska gå att använda av hela gruppen.

Mini-Definition of Done för hotanalysen:

1. Attackkedjan är dokumenterad i en logisk ordning.
2. Relevanta tactics och techniques är motiverade med källor.
3. Observationer och antaganden är tydligt separerade.
4. Osäkerheter och informationsluckor är dokumenterade.
5. Minst en relevant försvarsfråga finns för varje steg.
6. Riskreducerande åtgärder eller förbättringsförslag är prioriterade.
7. Analysen har granskats av minst en annan person i gruppen.
8. Resultatet har uppdaterats i backlog eller annat projektunderlag.

Uppgift 20

Beskriv vad som gör en hotanalys användbar för någon annan än den som skrev den.

Svarsinstruktion: Skriv 150-250 ord. Fokusera på tydlighet, spårbarhet och mottagare.

En hotanalys blir användbar för andra när den är tydlig, spårbar och anpassad till mottagaren. Den som läser ska kunna förstå vad som har observerats, hur analysen har genomförts och varför vissa slutsatser har dragits. Därför är det viktigt att skilja mellan fakta, antaganden och osäkerheter.

Spårbarhet är också viktig. Om en TTP-mappning har gjorts bör det gå att se vilken källa och vilken observation som ligger bakom. Då kan en annan person kontrollera resonemanget och uppdatera analysen när ny information kommer. Utan detta riskerar hotanalysen att bara bli en personlig tolkning.

Mottagaren spelar också roll. Ett säkerhetsteam kan behöva mer detaljer om signaler och kontroller, medan ledningen främst behöver förstå risk, konsekvens och prioritering. En bra hotanalys behöver därför vara strukturerad så att olika personer kan hitta relevant information. Jag tycker att den bästa analysen är den som någon annan kan ta över, granska och använda utan att behöva fråga originalförfattaren om varje detalj.

Del 6 - Koppling till backlog, sprint och Workshop 3

Uppgift 21

Uppdatera er backlog baserat på det ni upptäckte i Workshop 2.

Svarsinstruktion: Skriv minst fem nya eller ändrade backlog items. Ge kort motivering.

1. Förbättra loggning för relevanta steg i attackkedjan – eftersom analysen visade informationsluckor.
2. Skapa eller förbättra detektionsregler för prioriterade beteenden – för att korta tiden till upptäckt.
3. Dokumentera normal aktivitet/baslinje – för att lättare kunna bedöma avvikelser.
4. Granska TTP-mappningar i grupp – för att fånga alternativa tolkningar och förbättra kvaliteten.
5. Testa och uppdatera incidentrutiner – för att säkerställa att det finns en tydlig uppföljning vid larm.
6. Dokumentera osäkerheter som egna backlog items – så att obesvarade frågor inte glöms bort.

Uppgift 22

Beskriv hur er attackkedja förhåller sig till ert Sprint Goal.

Svarsinstruktion: Är sprintmålet fortfarande relevant? Behöver något justeras?

Attackkedjan är relevant för Sprint Goal eftersom den ger en tydligare bild av vad projektet behöver kunna analysera och försvara mot. Om sprintmålet handlar om att förbättra säkerhetsövervakning eller hotanalys ger kedjan en konkret struktur för vilka delar som behöver prioriteras.

Jag tycker dock att sprintmålet kan behöva förtydligas med mätbara resultat, till exempel att prioriterade delar av kedjan ska ha dokumenterad loggning, relevanta detektionsidéer och tydliga osäkerheter. På så sätt blir kopplingen mellan analys och faktiskt projektarbete starkare. Själva målet behöver inte bytas ut, men backloggen och prioriteringen kan justeras utifrån det vi lärde oss.

Uppgift 23

Formulera minst två uppföljningsfrågor inför Workshop 3.

Svarsinstruktion: Frågorna ska kunna användas vid review eller retrospektiv.

1. Vilka delar av vår attackkedja är fortfarande baserade på antaganden, och vilken information behöver vi samla in för att minska osäkerheten?
2. Vilka förbättringar från backloggen ger störst värde för upptäckt och riskreducering under nästa sprint?
3. Vilka delar av analysen fungerade bra i samarbetet, och vad bör vi ändra i vårt arbetssätt inför nästa sprint?

Uppgift 24

Förbered en kort statusrapport till Workshop 3.

Svarsinstruktion: Skriv 5-7 punkter: vad ni gjorde, vad som blev klart, vad som är oklart och vad ni vill ändra.

- Vi använde MITRE ATT&CK och TTP-begreppen för att strukturera vår hotanalys.
- Vi byggde en enkel defensiv attackkedja med tydliga tactics som etiketter.
- Vi identifierade försvarsfrågor, möjliga detektionssignaler och riskreducerande åtgärder.
- Vi dokumenterade osäkerheter och såg att vissa steg behöver mer underlag och bättre loggning.
- Vi tog fram nya och ändrade backlog items utifrån analysen.
- Inför Workshop 3 vill vi prioritera de största informationsluckorna och granska våra TTP-mappningar.
- Vi vill också följa upp om våra föreslagna förbättringar går att koppla tydligare till Sprint Goal och Definition of Done.

Frivillig fördjupningsutmaning

Skapa en komplett mini-hotanalys baserad på din Workshop 2-kedja.

Inkludera: mål med analysen, attackkedja, TTP-tabell, försvarsfrågor, källor, osäkerheter, uppdaterad backlog och förslag till nästa sprint. Max tre sidor.

Rekommenderade referenser

- MITRE ATT&CK: <https://attack.mitre.org/>
- MITRE ATT&CK Enterprise Matrix: <https://attack.mitre.org/matrices/enterprise/>
- CISA - Best Practices for MITRE ATT&CK Mapping:
<https://www.cisa.gov/news-events/news/best-practices-mitre-attckr-mapping>
- MITRE ATT&CK Data & Tools: <https://attack.mitre.org/resources/attack-data-and-tools/>

Bedömningskriterier

Bedömningen fokuserar på analysförmåga, begreppsanvändning, spårbarhet, defensivt perspektiv och koppling till projektarbete.

Matrisen är formulerad med kursens nivåer Godkänt (G) och Väl godkänt (VG). Den mellersta kolumnen beskriver kvaliteter som stärker bedömningen inom godkänd nivå och kan användas som stöd i återkoppling.

Bedömningsområde	Grundläggande krav för G	Tydliga kvalitetskännetecken	Kvalitetskännetecken för VG
Förståelse för MITRE ATT&CK	Kan beskriva ATT&CK på en grundläggande nivå och visar förståelse för ramverkets syfte.	Förklarar ATT&CK med egna ord och kopplar ramverket till hotanalys och säkerhetsarbete.	Visar fördjupad förståelse för ATT&CK som analysramverk och resonerar kring styrkor, begränsningar och användningsområden.
TTP-förståelse	Kan identifiera tactic, technique och procedure samt beskriva skillnaden översiktligt.	Använder TTP-begreppen konsekvent och förklarar sambanden mellan dem.	Använder TTP som ett naturligt analysverktyg och kan motivera val samt alternativa tolkningar.
Attackkedjor	Har skapat en enkel attackkedja där stegen följer en logisk ordning.	Attackkedjan är väl motiverad och sambanden mellan stegen förklaras.	Analysen visar systemsyn och används för att resonera kring risker och försvarsperspektiv.
Försvarsfrågor	Har formulerat relevanta försvarsfrågor.	Försvarsfrågorna är välformulerade och kopplas till upptäckt, begränsning eller uppföljning.	Kopplar angriparbeteenden till flera möjliga försvarsperspektiv och resonerar kring prioritering.
Källor och spårbarhet	Anger källor och referenser till analysunderlaget.	Motiverar hur källorna används och visar förståelse för spårbarhet.	Reflekterar kring källornas styrkor och begränsningar och håller hög dokumentationskvalitet.
Projektarbete	Har uppdaterat backlog eller projektunderlag.	Kopplar analysen till Sprint Goal, backlog eller Definition of Done.	Visar hur analysen skapar värde i projektet och resonerar kring prioritering, risk och nästa steg.

Samlad bedömning

Godkänt (G)

Studenten har genomfört huvuddelen av uppgifterna, visar grundläggande förståelse för ATT&CK, kan beskriva en enkel attackkedja, kan formulera relevanta försvarsfrågor och kan dokumentera sitt arbete.

Väl Godkänt (VG)

Studenten visar god analytisk förmåga, använder ATT&CK och TTP konsekvent, motiverar sina slutsatser, identifierar osäkerheter, visar god förståelse för försvarsperspektivet och kopplar analysen till projektets mål och arbetssätt.